

LIVRO BRANCO

Sistemas de médio porte e mainframe para segurança

Ferramenta de controle de conformidade com políticas

Pierre Cailloux

Certificação GIAC Security Essential (GSEC)

**Ferramenta de controle de conformidade com
políticas de segurança para sistemas de médio e
grande porte (Midrange e Mainframe).**

Certificação GIAC Security
Essentials (GSEC)
Tarefa prática versão 1.4c

Opção 2

Submetido por: Pierre CAILLOUX, 1 de dezembro de 2004.
Conferência SANS - Londres - junho de 2004.

RESUMO

O objetivo deste documento, no âmbito do exame prático para o GSEC1, é apresentar as diretrizes para a preparação para o exame. A opção 2 do SANS2 consiste em apresentar uma solução para uma empresa, de forma a permitir a gestão e aplicação de regras de segurança informática em sistemas Mainframe e Midrange, bem como em sistemas de gestão de instalações, em conformidade com outras regras de segurança específicas dos clientes.

Com a ajuda de uma ferramenta compatível com a plataforma de SO Z/OS MVS3, VM Z/OS, OS4004 e o produto de segurança: RACF5, ACF26, CA TSS7. Esta ferramenta opera em uma tabela de leis aplicável a qualquer sistema computacional, conjunto de sistemas ou sistema específico. A ferramenta cria comandos executáveis em diversos sistemas gerenciados por ela, para que as regras de segurança sejam aplicadas. Envia notificações de controle por e-mail aos indivíduos afetados em seus respectivos cargos, utilizando uma tabela de destinatários. Além disso, realiza parte da validação das notificações de controle por meio do protocolo ISPF/TSO8, conforme selecionado na ferramenta.

Propósito

- Controlar a proteção de elementos de segurança sensíveis
- Fornecer instalações para a gestão de eventos
- Analisar a proteção dos recursos sensíveis do sistema operacional
- Controlar as regras de conformidade do relacionamento
- Fornecer relatório de limpeza 9 (subsistema)
- Enviar relatório aos administradores responsáveis

Metodologia

- Armazene todos os registros confidenciais em tabelas DB210
- Incorporar automaticamente recursos sensíveis do sistema operacional com um nível atribuído
- Enviar relatórios por e-mail
- Registros de atividades do administrador
- Arquivar relatórios como evidência de controle

¹ GSEC (GIAC) Certificação Global de Garantia da Informação - Certificação essencial em segurança

² SANS instituto

³ Armazenamento virtual múltiplo Z/OS MVS, máquina virtual Z/OS VM (IBM System 370 e 390)

⁴ OS400 (Sistema operacional 400) para sistema IBM de médio

⁵ RACF 6 (Recurso de Controle de Acesso) Software de segurança IBM

⁶ ACF2 (Computer Associates) Software de segurança

⁷ CA TSS (Computer Associate) Software de segurança

⁸ ISPF / TSO (interactive system productivity facility, opção de compartilhamento de tempo) Software IBM IDS

⁹ de controle de "manutenção" encontrados em um subsistema de produto (DB2, ...) e não encontrados no produto de segurança do sistema.

¹⁰ DB2 (banco de dados 2) um sistema de gerenciamento de banco de dados relacional da IBM

Índice

Resumo.....	2
Índice.....	3
Lista de Figuras	4
Descrição do problema.....	5
introdução.....	6-7
Visão geral da ferramenta.....	8
A FERRAMENTA.....	9-21
Pré-requisito	9
Conceito de ferramenta	10
Plataforma universal	11
Dados de segurança	11
Extrator de dados	11
Centralização de dados	12
Modelagem de dados	12-14
Repositório de dados	14
Dador	14
Validação de referência	14
Interface ISPF	15-18
Controles de saída	18
Comandos	18
E-mails.....	19
Relatório de controle de conformidade	19
Relatório Delta	20
Relatório/ Análise.....	20
Gestão de documentos	20
Validação contínua da necessidade de negócios (CBN).....	21-22
Fluxo.....	23-24
Qualidades da ferramenta	25-28
Custo/Economia.....	28
Referências	29
Resumo.....	30
Anexo 1: Extrator de dados	31
Anexo 2: Modelagem.....	32
Anexo 3: Exemplo de modelagem de dados de segurança	33

Lista de Figuras

Figura 1: Arquitetura da ferramenta.....	8
Figura 2: Padronização de pré-requisitos	9
Figura 3: Conceito de ferramenta	10
Figura 4: Centralização de dados.....	12
Figura 5: Modelagem de dados.....	13
Figura 6: Painel primário ISPF.....	15
Figura 7: Monitoramento do Ponto Focal do ISPF	16
Figura 8: Gerenciamento da tabela de referência ISPF	17
Figura 9: Detalhes do ISPF em um recurso.....	18
Figura 10: CBN (Necessidade Contínua de Negócios)	21
Figura 11: Fluxo de dados.....	23
Figura 12: Exemplo de fluxo de dados.....	24
Figura 13: Nível de período de segurança	25
Figura 14: Exemplo de sistemas OS/400	27

Marcas registradas

Os termos a seguir, utilizados nesta publicação, são marcas registradas da IBM Corporation. nos Estados Unidos ou em outros países.

DB2 CICS IMS MVS NETVIEW OS/390 OS/400 ISPF
RACF QMF

IBM ® International Business Machines Corporation

E o termo a seguir é uma marca registrada da Computer Associates, INC (CA).

Top secret ® ACF2 , TSS.

DESCRIÇÃO DO PROBLEMA

Muitas empresas aplicam e gerenciam suas regras de segurança da computação conforme a necessidade, geralmente quando precisam comprovar conformidade a um órgão de controle de negócios. A revisão das implementações está se tornando cada vez mais importante no mundo da segurança, como abordado no capítulo "Defesa em Profundidade" do curso de segurança SANS¹. Para lidar com essa carga de trabalho de vigilância e aplicação de regras de segurança, foi necessário aumentar o número de funcionários. Inicialmente, as empresas criaram serviços completos de computação. A segurança deixou de ser uma atividade pontual e passou a ser exercida em tempo integral. A principal dificuldade reside em aplicar e manter as regras de segurança rapidamente, devido ao aumento do número de sistemas, sem que haja longos intervalos entre os controles e a aplicação das regras.

Como podemos saber se uma regra de segurança não está sendo aplicada a um conjunto de sistemas computacionais?

Para uma nova regra de segurança, quais são os sistemas em desacordo e qual o impacto em todo o parque computacional gerenciado pela ferramenta?

Todas essas questões são levantadas pelas empresas, e o atraso na aplicação dessas novas regras de segurança é geralmente um fator importante. Elas se somam a outras regras já existentes que ainda não foram implementadas.

Assim, muitas empresas deixam seus sistemas de informática aos cuidados de profissionais. A impressão digital da chave se tornou um mercado emergente para muitas empresas chamado "Terceirização".

A ferramenta precisa atender aos requisitos de auditoria de segurança. Ela também pode ser usada para atender à Responder a alguns dos controles de padrões, como ISO90002. , norma SAS703 .

¹ Instituto SANS

² ISO 9000 Organização Internacional de Normalização

³ Declaração SAS70 sobre Normas de Auditoria Número 70 (lei de controle interno "Sarbanes-Oxley")

INTRODUÇÃO

Políticas e processos são vitais para a segurança da informação. Esta ferramenta de software, executada principalmente em sistemas Mainframe MVS¹, é capaz de realizar revisões periódicas e automáticas de segurança. Boas práticas de segurança de dados estão se tornando cada vez mais importantes devido a uma série de tendências, como:

- Grande número de sistemas interconectados
- Utilização de linguagens de alto nível fáceis de usar
- Familiaridade geral com processamento de dados
- Fácil acesso às informações armazenadas em bancos de dados

Sem a implementação de práticas adequadas de segurança de dados, esses avanços podem resultar em uma maior probabilidade de pessoas não autorizadas acessarem, modificarem ou destruírem dados, seja inadvertidamente ou deliberadamente.

Meu objetivo é apresentar esta ferramenta em seu aspecto geral, destacando alguns pontos importantes em particular.

A ferramenta inclui as seguintes fases:

- O extrator (Coleta de dados)
- Transferência de dados
- Processamento do Ponto Focal
 - Modelagem
 - Implementação de regras de segurança
 - Processamento de dados
 - Controles
- Envio de relatórios
 - Controles de saída
 - Resultados da análise do relatório
 - Gestão de documentos
 - Dados disponíveis
- Controle adicional específico (controle local)

¹

MVS - armazenamento virtual múltiplo (IBM System 370 e 390)

Esta ferramenta é dedicada à segurança. Todos os relatórios enviados por ela são auditáveis. É importante ressaltar a responsabilidade dos destinatários. O relatório por e-mail é enviado ao administrador de segurança responsável. Os administradores são considerados responsáveis pelos itens de segurança dos sistemas de destino associados, detalhados no relatório. A ferramenta envia automaticamente todas as modificações em uma tabela de destino para validação a cada administrador. Você pode — e é recomendável — usar a parte de desenvolvimento localmente para gerar relatórios sob demanda para usuários, administradores ou clientes.

Sempre que necessário, projete procedimentos DB2/QMF1 para uso pontual com envio automático diário, semanal ou anual para um endereço de e-mail de referência.

Minha empresa me incumbiu da tarefa de elaborar esta ferramenta e desenvolver processos para enviar relatórios automáticos às pessoas envolvidas, incluindo os resultados encontrados pela ferramenta, as regras de segurança não conformes, os desvios, bem como o inventário anual dos dispositivos computacionais. Também devem ser geradas estatísticas para acompanhar a evolução da segurança em todos os sistemas computacionais gerenciados pela ferramenta. O suporte aos administradores sobre o uso da ferramenta e a manipulação de dados está disponível mediante solicitação ao DB2/QMF. Há vários anos participo ativamente da criação desta ferramenta na parte do DB2/QMF. Agora, esta ferramenta é minha e eu forneço suporte aos usuários para ajudá-los a compreender e desenvolver procedimentos locais e implementar novas políticas.

Participar dos cursos da SANS em junho passado foi de grande ajuda para mim. Minha mente se abriu para outras áreas técnicas. Agora consigo enxergar a conexão entre elas.

¹ Banco de dados DB2/QMF 2 (um sistema de gerenciamento de banco de dados relacional da IBM) Recurso de gerenciamento de consultas (um software da IBM)

VISÃO GERAL DA FERRAMENTA

A ferramenta compreende: (ver figura 1 abaixo)

- Os sistemas alvo e o extrator
- As transferências de segurança de dados
- O ponto focal
- A comunicação

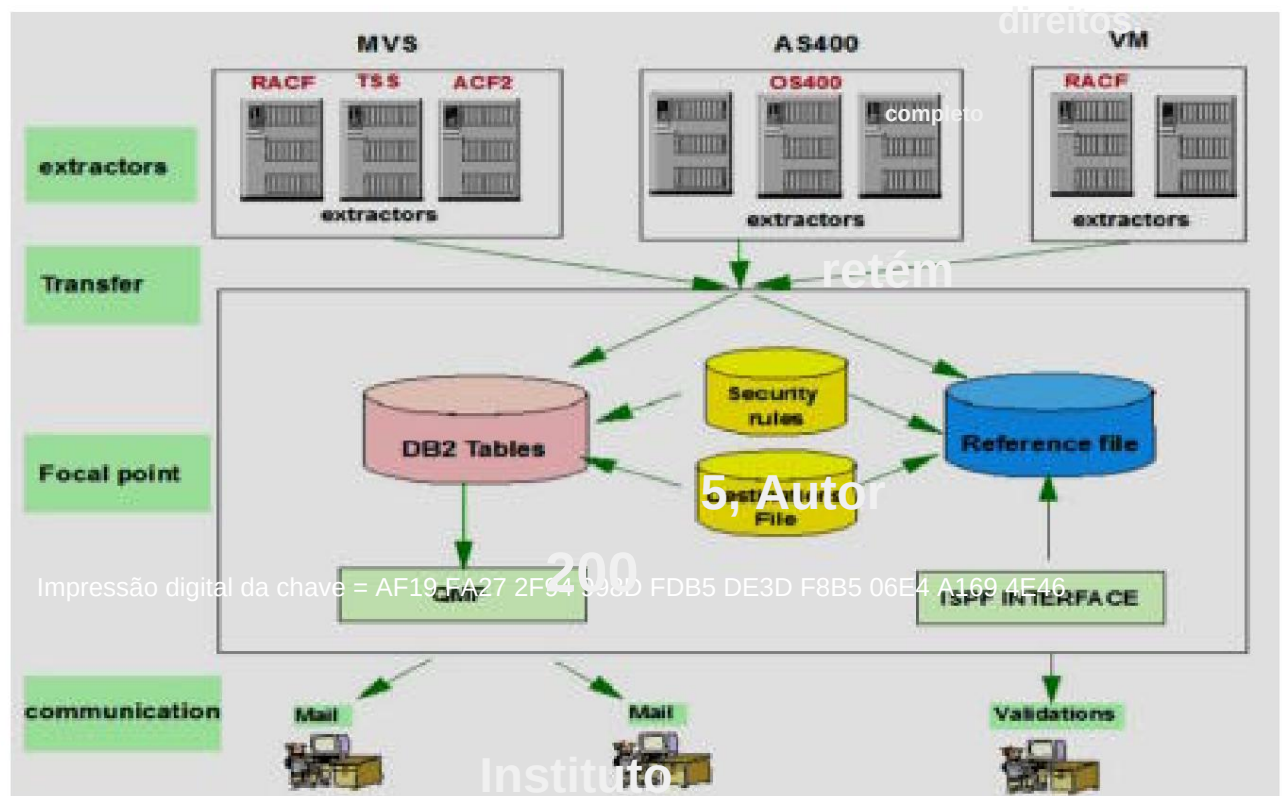


Figura 1: arquitetura da ferramenta

O ponto focal, que opera em um ambiente MVS¹, armazena os dados de segurança em repositórios de dados (DB2)² para análise. A análise de segurança é feita comparando os dados extraídos dos sistemas de destino com as regras gerais de segurança armazenadas em um arquivo de regras de segurança.

¹ MVS - armazenamento virtual múltiplo (IBM system 370 e 390)

² DB2 (banco de dados 2) é um sistema de gerenciamento de banco de dados relacional da IBM.

A FERRAMENTA

Pré-requisito

Numa primeira etapa, cada sistema computacional deve suportar uma atualização de arquitetura que inclui 10 fases de "projetos de padronização de sistemas". A ferramenta facilita essa padronização em todos os dados centralizados.

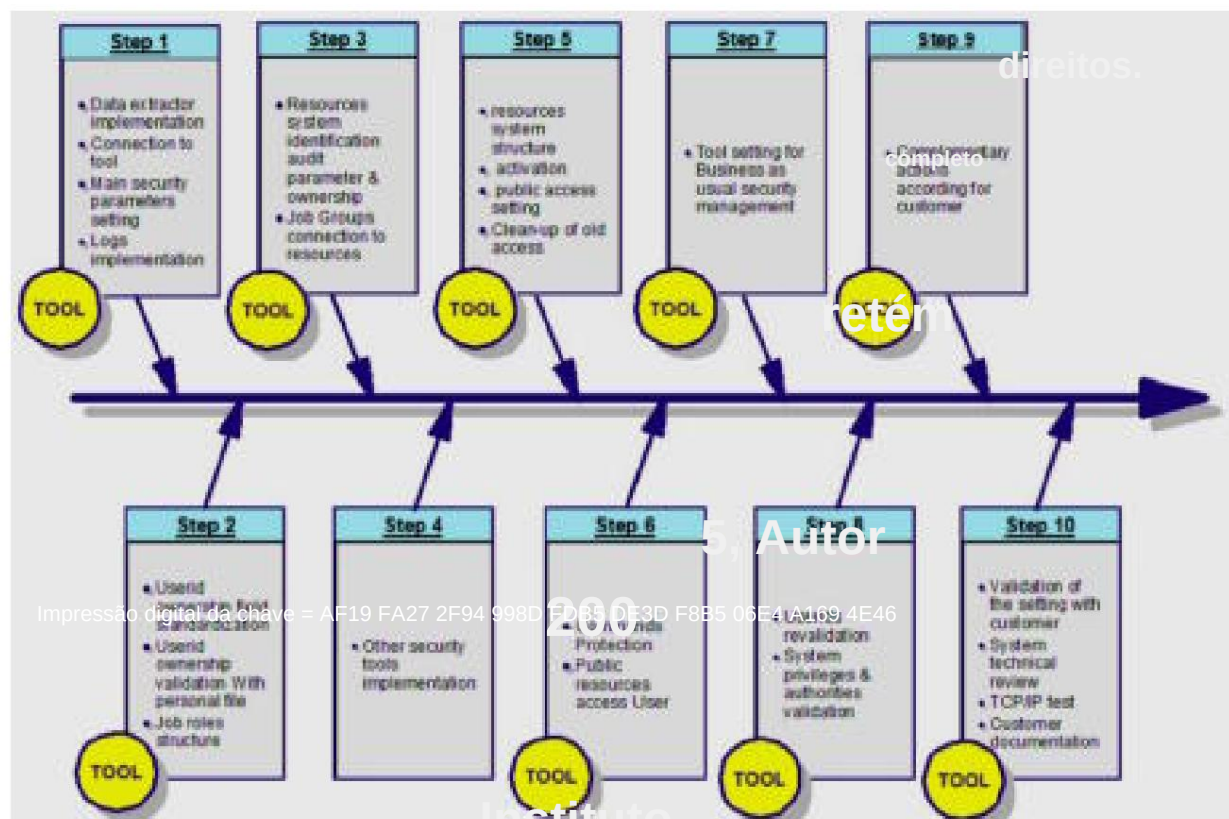


Figura 2: Padronização de pré-requisitos¹

Etapa 1: Coletar e armazenar os dados de segurança

Etapa 2: Padronização do Userids² para a ferramenta

Etapa 3: Padronização sensata dos recursos do sistema operacional

Etapa 4: Adaptar os registros para controle pela ferramenta ou outra ferramenta de segurança local.

Etapa 5: Padronizar os recursos sensíveis do sistema operacional

Etapa 6: Aplicar proteção de comando e acesso público com validação

Etapa 7: Personalizar o arquivo de referência

Etapa 8: Validação do ID de usuário privilegiado e das autorizações.

¹ Referência: Tarefa Prática GSEC de "Yves Depoorter", abril de 2004. "userid" O

² termo "user id" é um termo geral para indicar o usuário, o grupo, o grupo de ID de acesso ou o ID de login.

Etapa 9: Projetos complementares com subsistemas

Etapa 10: Validação da gestão do sistema de segurança

Cada etapa pode ser resequenciada com a ferramenta sendo executada repetidamente.

A ferramenta propõe um conjunto de regras de segurança padrão aplicáveis a cada plataforma gerenciada por ela; detecta os recursos sensíveis do sistema e propõe uma proteção para todos eles.

direitos.

Conceito de ferramenta

completo

O princípio geral da ferramenta é extrair dados de segurança de cada sistema para um ponto central e desenvolver processos para enviar automaticamente relatórios às pessoas envolvidas, incluindo os resultados encontrados pela ferramenta, ou disponibilizar dados de segurança controlados para validação pela ferramenta. As etapas intermediárias incluem a centralização de dados em um formato específico (modelagem), a manipulação de dados com tabela de regras de segurança e a preparação de relatórios para envio ou validação.

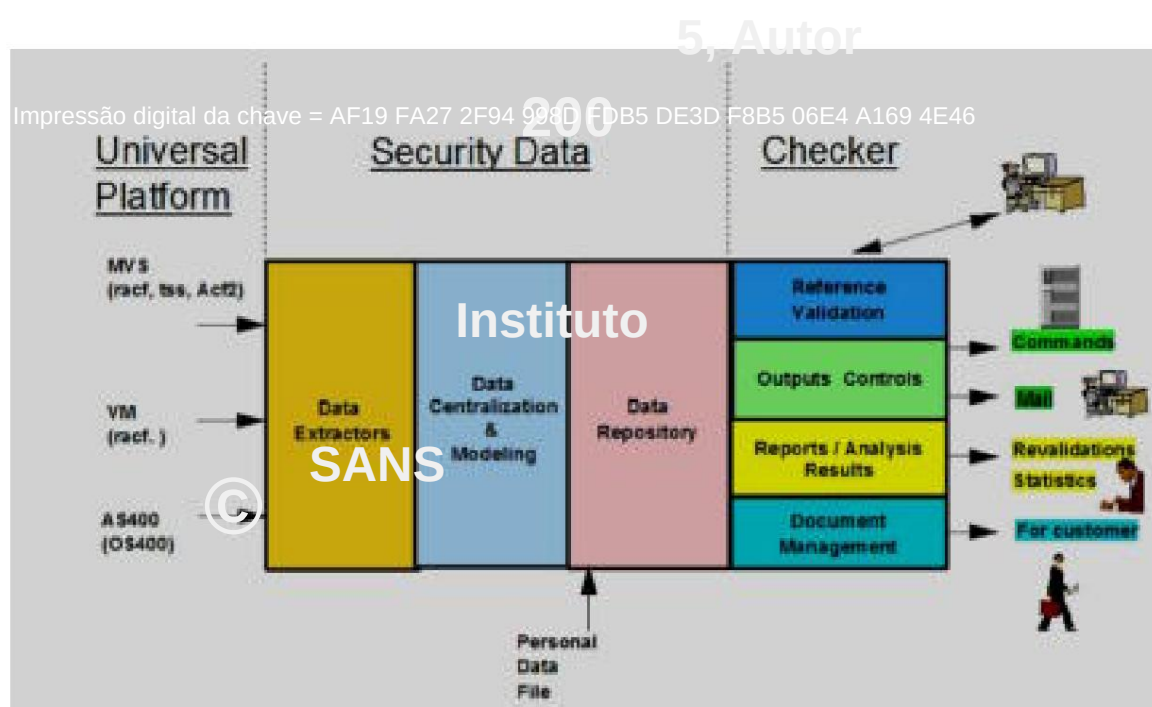


Figura 3: Conceito de ferramenta

Plataforma universal

Os extratores existentes são adaptados a cada plataforma mencionada na Figura 3. Um novo extrator poderia ser facilmente desenvolvido, pois possui um conceito básico para extrair todos os dados de segurança. Os dados serão "modelados" no sistema em questão para serem inseridos na aplicação.

Dados de segurança

Extrator de dados

Os dados de segurança e as informações do sistema são extraídos e enviados para um ponto central. Diversos utilitários são executados, como os utilitários RACF1 (DSMON, IRRDBU00)², comandos do sistema (DISPLAY) e comandos do subsistema (HLIST USER)³. Os dados são extraídos dessas saídas, mesclados em um único arquivo DATA e enviados ao ponto central de processamento como um arquivo compactado DFDSS DUMP⁴ em plataformas OS/390 e TERSED5 em plataformas VM/ESA⁶. Para o sistema OS400, o arquivo não é compactado, mas o extrator executa o comando "save object" com a opção compress = *yes.

A ferramenta é compatível com diferentes plataformas de sistemas operacionais e produtos de segurança, por isso os seguintes subcomponentes foram desenvolvidos:

- Extrator RACF/VM8 e RACF/MVS⁹
- Extrator OS/400¹⁰
- Extrator CA-TSS¹¹ OS/390¹²

O extrator é executado em cada sistema gerenciado pela ferramenta. O objetivo é capturar o máximo de dados relacionados à segurança, mesmo que não sejam necessários no momento, e minimizar a complexidade para evitar atualizações frequentes.

Um extrator é concebido para cada plataforma. Consulte o "Anexo 1" para obter informações sobre os diversos grupos de dados. Capturado em cada plataforma; uso de utilitários padrão para simplificar a manutenção.

¹ RACF (Resource Access Control Facility) - Software de segurança da IBM; DSMON

² IRRDBU00 - Extrai dados do monitor de segurança ou do software RACF; HLIST -

³ Comando USER para o software RACF; DFDSS DUMP

⁴ - Serviços de conjunto de dados do Data Facility (produto de software da IBM).

⁵ Arquivo compactado de software conciso para sistema

⁶ VM VM/ESA (máquina virtual/arquitetura de sistemas empresariais) (IBM)

⁷ OS400 Sistema operacional IBM para AS/400

⁸ RACF (Resource Access Control Facility) Software de segurança IBM MVS

⁹ Armazenamento virtual múltiplo (IBM System 370 e 390)

¹⁰ OS400 Sistema operacional IBM para AS/400

¹¹ CA-TSS Computer Associates International, Inc.

¹² Sistema operacional IBM OS/390 390

Centralização de dados

O processo de centralização de dados consiste em realizar uma transferência em um curto período de tempo e utilizar uma transmissão padrão adaptada a cada plataforma ou ambiente do cliente.

Os arquivos são compactados no sistema de destino e descompactados no sistema central. Veja a figura 4 abaixo. Um estudo é realizado com o cliente para definir o método de criptografia, principalmente no que diz respeito aos dados transferidos para fora da intranet.

Antes de transferir os dados de segurança, o ICSF1 pode ser usado para criptografar os dados entre sistemas remotos e o sistema central.

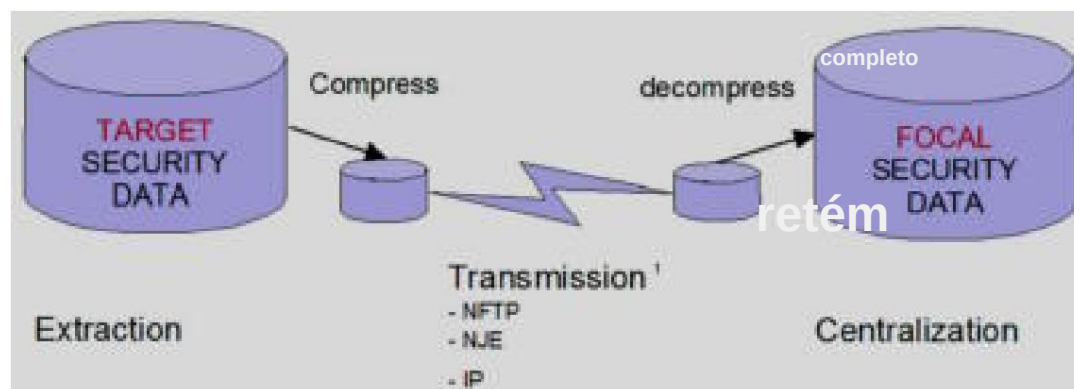


Figura 4: Centralização de dados

Modelagem de dados

O conjunto de dados é modelado para distinguir os diferentes sistemas computacionais, as diversas plataformas e os diferentes subsistemas que compõem as várias entidades específicas, visando um controle preciso durante o pós-tratamento. O objetivo é classificar todos os dados em categorias com uma entidade combinada por convenção.

A opção é escolher 3 palavras-chave:

Identificação do tipo da categoria de domínio

“**DOMÍNIO**” : Inserimos o nome do sistema operacional, do software de segurança ou do subsistema.

“**CATEGORIA**” : Para o sistema operacional, indicamos os objetos computacionais dependendo de sua vocação ou do nome do subsistema.

“**TIPO**” : Aqui, indicamos o tipo na categoria de domínio combinada “tipo”.

De forma geral, temos aqui noções de autoridade, acesso público ou definição de contexto.

¹ ICSF - Serviço Criptográfico Integrado (software IBM)

² Transmissão NFTP (programa de transferência de arquivos NetView) NJE (entrada de trabalho na rede) IP (protocolo da internet)

Ao formar uma entidade chamada «source», um nome de sistema e um nome de imagem são adicionados para antecipar o megaplexo do sistema¹. Na Figura 6, podemos observar que todos os dados de segurança, independentemente de sua origem, estão sujeitos à «modelagem» para entrar no aplicativo.

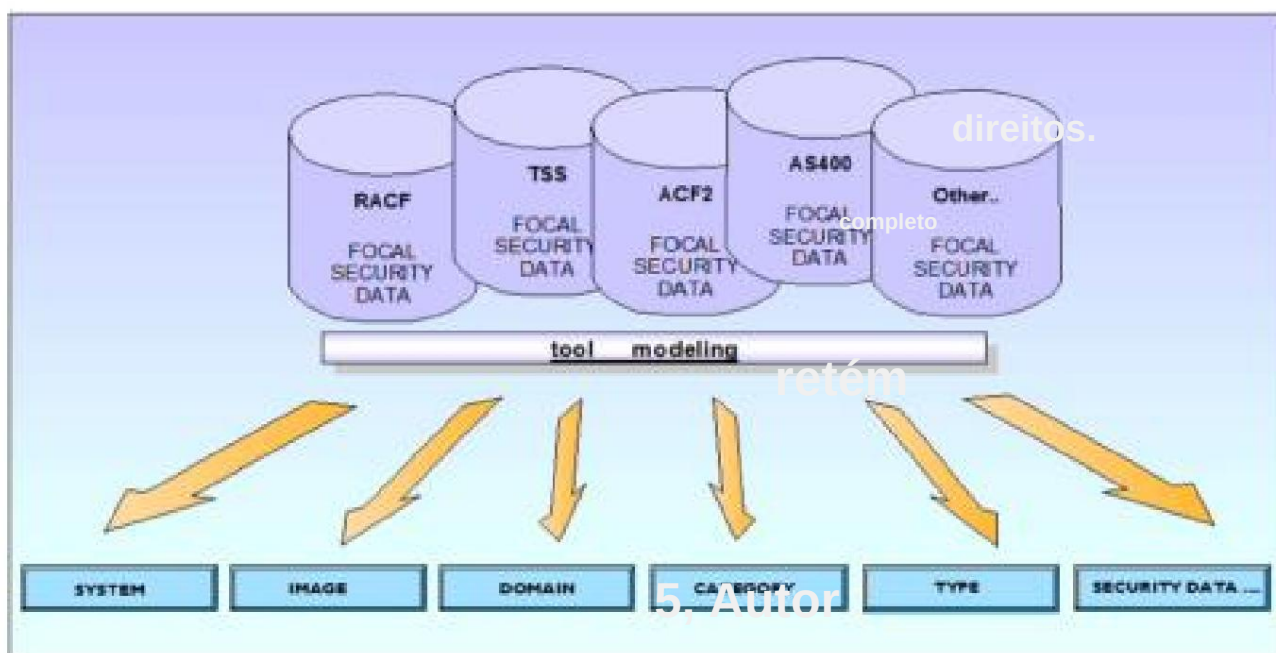


Figura 5: Modelagem de dados

Por exemplo: se usarmos o sistema operacional MVS2 e o software de segurança RACF3, obteremos a categoria USERID.

IMAGEM DO SISTEMA	TIPO DE CATEGORIA DE DOMÍNIO				VALOR
Systxx	Imagem 2	RACF	ID DO USUÁRIO	BÁSICO	Propriedade do AUTOTASK1
Sistema	Imagem 3	RACF	ID DO USUÁRIO	AUT.	Operação AUTOTASK1
Systzz					

Entidades conhecidas como «fonte» podem ser construídas pela ferramenta; essas fontes são úteis para aplicar as leis e extrair os desvios.

¹ megaplex, um sistema de hardware com vários sistemas aqui, como na imagem.

² MVS - Armazenamento Virtual Múltiplo (IBM System 370 e 390)

³ RACF (Resource Access Control Facility) - Software de segurança da IBM

IMAGEM DO SISTEMA	TIPO DE CATEGORIA DE DOMÍNIO			VALOR
Systxx	Imagem 2	RACF	OSR	ACESSO nome
Sistema	Imagem 3	RACF	OSR	BÁSICO SYS1.* nome de usuário LEITURA QSYS
Systas400		OS400	OSR	db2jobsec *lib BÁSICO

OSR: Recursos do sistema operacional: recursos sensíveis do sistema e seus acessos.

Consulte os diversos exemplos de fontes no Anexo 2.

O exemplo de uma parte dos dados de segurança para configurações RACF de mainframe (opções globais) está no Anexo 3.

A lista de dados de segurança com a modelagem RACF RACF SETTING SETROPTS.

Este exemplo mostra como é possível adaptar uma regra para aplicar uma política.

A opção de configuração "addcreator" deve estar "ativa". A ferramenta compara os dados de segurança com as regras a serem aplicadas. Se os dados de segurança não estiverem em conformidade com as regras, um relatório será enviado ao administrador correspondente ao TIPO DE CATEGORIA DE DOMÍNIO indicado na tabela de destinatários.

SYST	SYSE DOMAIN	CATEGORY	TYPE	DATA SECURITY	VALOR
SYSTHVS	MVSA RACF	RACF	SETTING SETROPTS	ADDCREATOR	INACTIVE

Impressão digital da chave = AF19 FA27 2F94 995D 1505 DE3D F8B5 06E4 A169 4E46

Repositório de Dados

O «repositório de dados» compreende 4 conjuntos de dados, distribuídos por um conjunto de tabelas DB2/QMF:

Um primeiro conjunto de dados corresponde exatamente a imagem do sistema.

Uma segunda versão dos dados gerados pela ferramenta.

Um terceiro anexo contém dados relativos à «organização de pessoal», incluindo endereços de e-mail, bem como informações sobre o colaborador, seu gestor e o gestor do gestor.

Uma quarta opção para dados estatísticos.

Verificador

Validação de referência

Utilização de uma tabela de leis (A segurança da informação é um componente vital para o sucesso dos negócios). A implementação das leis pelo administrador é garantida em uma tabela, com a possibilidade de testar o resultado de sua implementação em todo o conjunto de sistemas e avaliar o impacto.

Interface ISPF1

A interface ISPF é utilizada na ferramenta MVS2 Focal Point. Painéis específicos para a ferramenta foram criados, exibindo apenas os elementos relevantes para o administrador, com a possibilidade de alternar para os backups administrativos. O processo delta propõe diversos caminhos dentro das diferentes fontes de dados. O painel ISPF inclui o controle de não controle, o registro de logs, o envio de e-mails e, por fim, o controle de validação; no painel de validação de dados para uma fonte específica, encontramos novamente a entidade denominada "fonte", com a indicação das ações a serem tomadas ou o estado atual. Todos os dados de segurança estão presentes na interface ISPF e podem ser consultados a qualquer momento. Para cada elemento, o administrador pode selecionar e visualizar os detalhes, podendo assim tomar a decisão sobre a ação a ser executada.

completo

retém

Painel de seleção de fonte

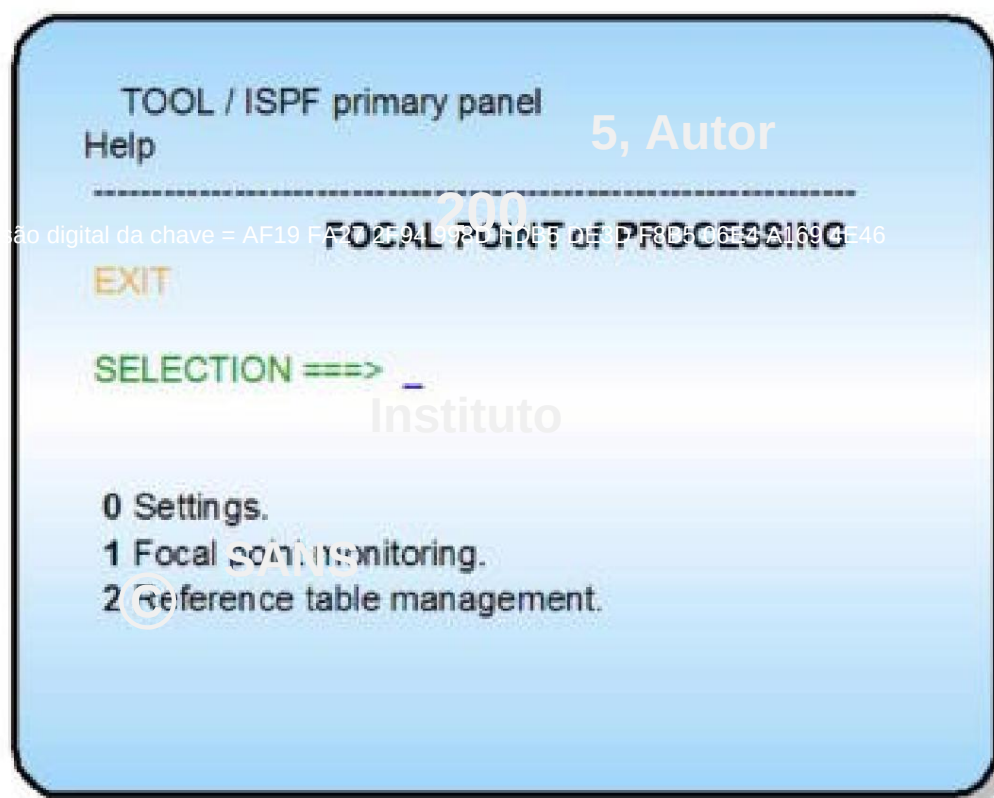
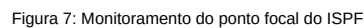


Figura 6: Painel primário do ISPF

¹ ISPF - Sistema Interativo de Produtividade, um software da IBM

² MVS - armazenamento virtual múltiplo (IBM system 370 e 390)

Tabela de regras
Tabela de Destino
Tabela do sistema



O autor mantém todos os direitos.

Painel de seleção de fonte

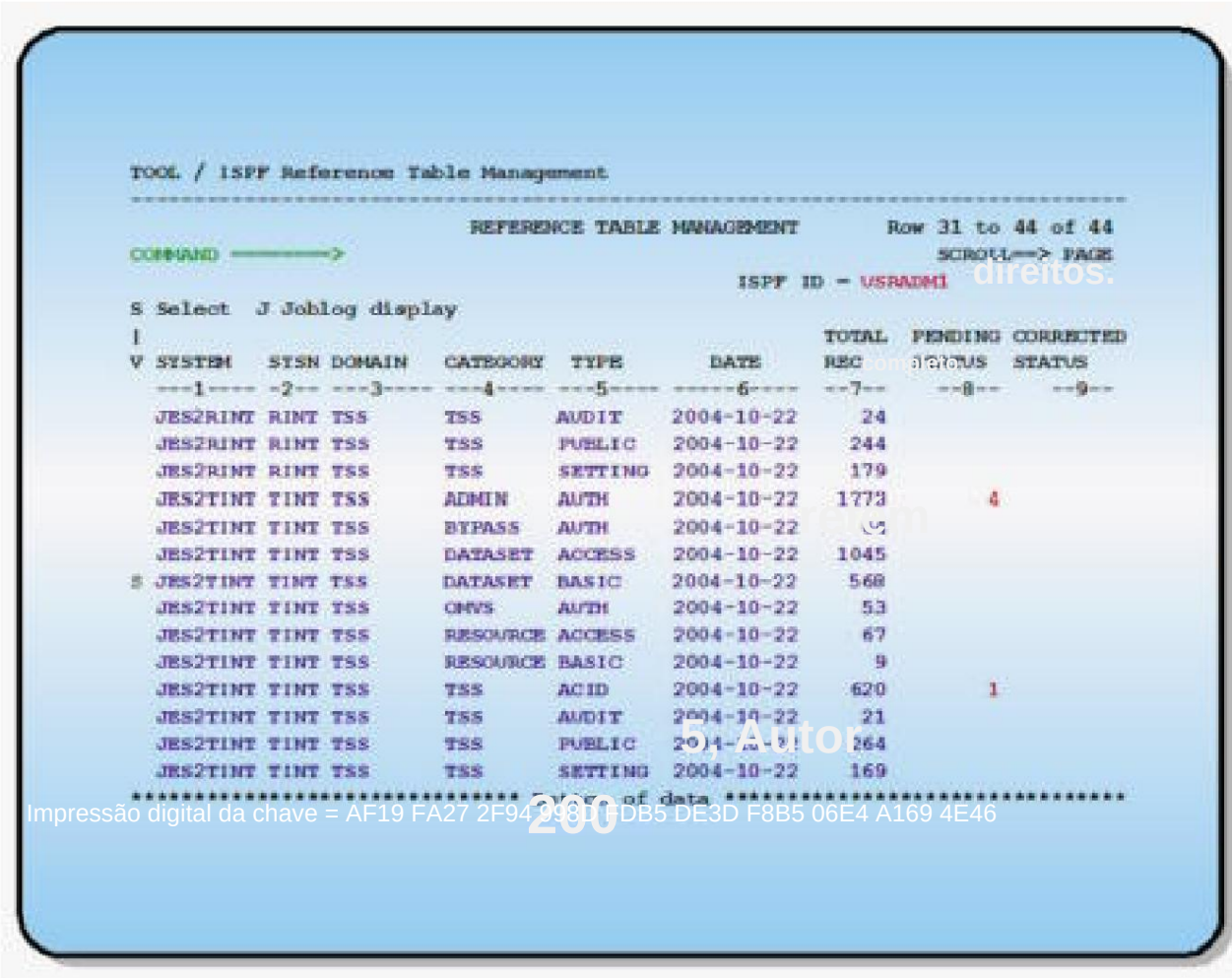


Figura 8: Gerenciamento de tabelas de referência

Esta opção permite visualizar e gerenciar os dados de segurança coletados dos sistemas de destino. Nesta fonte de dados de segurança, todos os itens estão presentes; e o processo delta indica as alterações nos registros.

Detalhes da seleção de um item

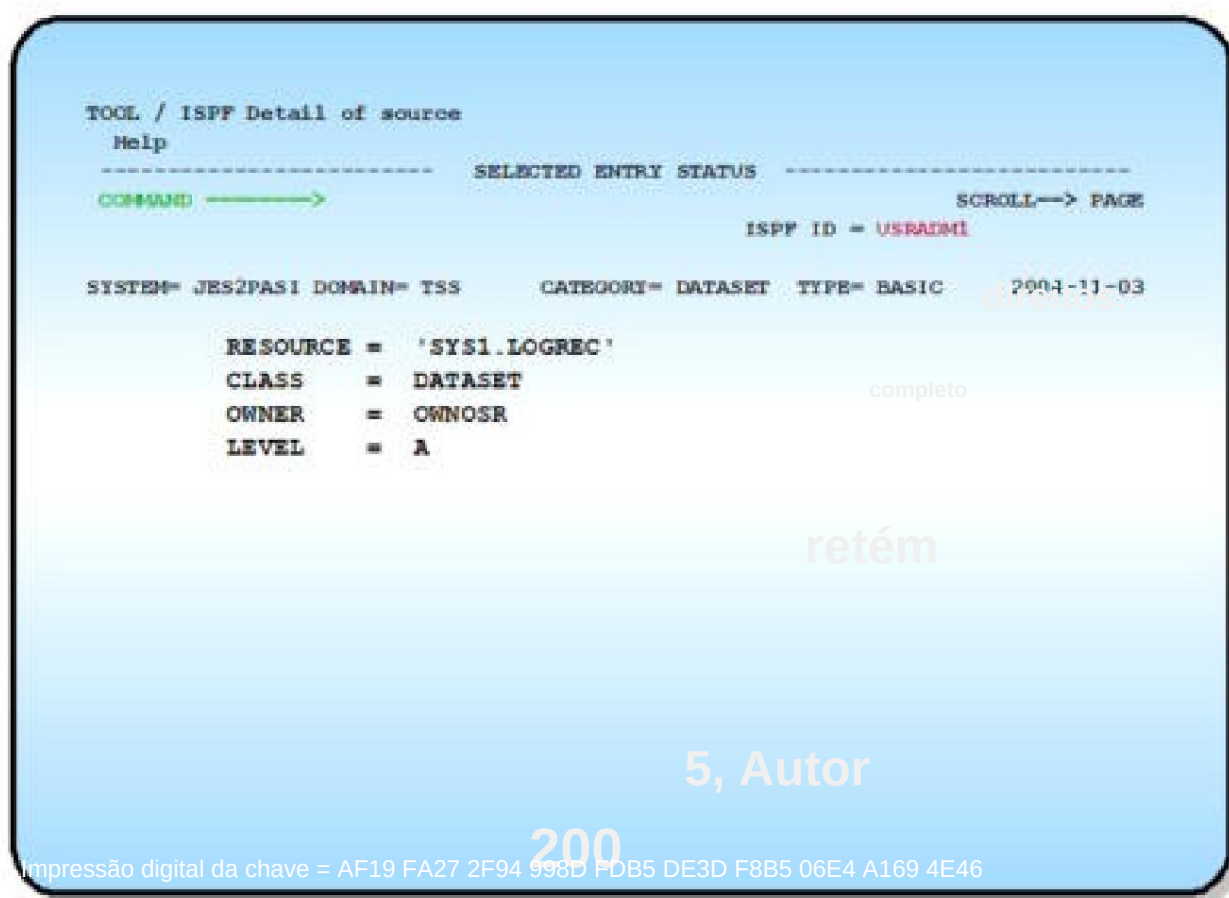


Figura 9: Detalhe do ISPF em uma fonte

A tela acima é um exemplo da exibição quando um S (Selecionar) é inserido; e se for uma variação gerada pela ferramenta, ela poderá ser aceita.

Controles de saída

Comandos:

A ferramenta gera comandos corretivos executáveis para cada sistema; um primeiro arquivo com comandos executáveis não é analisado pelo administrador, e há outro arquivo com sugestões de comandos executáveis para cada sistema.

Por exemplo:

- Uma ordem de alteração organizacional (novo número de serviço ou próximo gerente para uma conta individual)
- Uma proposta para cancelar a conta de alguém que deixou a empresa.
- Um comando de modificação de propriedade para um recurso sensível, seguindo uma regra de segurança escrita na tabela de leis.

E-mails:

A ferramenta está configurada para enviar relatórios por e-mail aos administradores de segurança apropriados. O tipo, a frequência e o conteúdo desses relatórios são adaptados à necessidade específica do destinatário. A ferramenta propõe a escolha do formato (texto simples ou HTML).

Existem dois tipos diferentes de relatório:

- Relatório de controle de conformidade

O relatório de controle de conformidade é geralmente fornecido regularmente. Este relatório é frequentemente chamado de relatório semanal, embora possa ser elaborado com maior ou menor frequência.

Este relatório está dividido nas seguintes seções: 1. Controle de propriedade do usuário 1

Todo esse controle consiste na detecção de discrepâncias de propriedade das chaves de acesso ao sistema computacional. As contas são registradas com uma chave de propriedade nos programas de segurança para cada plataforma apropriada e uma comparação com um arquivo de organização pessoal.

As chaves registradas nos programas de segurança fazem parte dos pré-requisitos para o correto funcionamento dos controles da ferramenta.

2. Controle de conformidade

A seção de controle de conformidade tem como objetivo verificar as configurações de segurança em relação às regras predefinidas e outras para a implementação de regras locais.

3. Conformidade com as regras OSR

Na ferramenta, é implementada uma detecção de configuração padrão com um nível atribuído ao perfil. O perfil entra automaticamente no processo de controle de conformidade.

Por exemplo: o processo detecta o recurso sensível do sistema operacional se o parâmetro UACC (Acesso Universal) for diferente de "NENHUM".

4. Controle de limpeza

O controle de segurança tem como objetivo indicar quaisquer discrepâncias entre as configurações de segurança do software em execução no sistema de destino e as configurações correspondentes no sistema operacional. Esta seção identifica quando uma ação corretiva é necessária.

Por exemplo: o ID do usuário no subsistema em execução no sistema de destino deve ser identificado no banco de dados de segurança.

5. Resumo da seção de desvios

O objetivo da seção de resumo de desvios é sintetizar todos os desvios encontrados no relatório.

¹ "ID de usuário" é um termo genérico para indicar o usuário, o grupo, o grupo de acesso ou o ID de login.

- Relatório Delta

O relatório delta indica as alterações nas configurações de segurança entre duas execuções consecutivas. Antes da execução, um novo resultado do extrator deve ser carregado no ponto focal.

Geralmente, essa execução é um processo diário. Mas pode ser executada em outro período.

Este relatório é composto por duas seções:

1. O processo Delta

Esta seção indica todas as diferenças entre uma execução e outra em todos os dados de segurança para fins informativos. Este parâmetro deve ser indicado na tabela de destino (I: de Informação).

2. Estatísticas sobre o tempo de espera para validação no âmbito do ISPF.

Esta seção indica os relatórios que possuem alterações nos parâmetros de segurança e que aguardam validação manual por meio da interface ISPF1.

Rq: em uma tabela de destino, uma coluna indica para cada origem se a informação vai para o relatório delta, validação do painel ISPF ou nenhum controle. E a ferramenta permite enviar um relatório para o e-mail do administrador de backup.

Relatórios / Resultados da análise

Revalidação

Consulte o capítulo CBN.

Estatísticas

Dois tipos de estatísticas são produzidos pela ferramenta: •

Estatísticas para um sistema onde a atividade do sistema é gerada, listando as atividades.

- Estatísticas para um sistema onde os resultados dos controles realizados pela ferramenta são mostrados.

Gestão de documentos

A gestão documental consiste na síntese de todos os dados com uma porcentagem de nível de segurança, a fim de evidenciar claramente os pontos fortes e fracos. Este documento foi concebido para ser visualizado pelo cliente e para servir de base para a discussão de um plano de melhoria.

¹

ISPF: Instalação de Programação de Estrutura Interativa

Validação contínua da necessidade de negócios (CBN)

A validação de objetos computacionais é uma regra de segurança. Periodicamente, uma lista precisa ser enviada aos administradores de serviço, tanto para eles próprios quanto para seus colaboradores. Para que essa revalidação seja possível, a estrutura de propriedade precisa ser implementada. Uma relação é estabelecida entre os dados de segurança implementados no software de segurança e os dados pessoais, onde endereços de e-mail podem ser encontrados.

As tabelas DB2 na ferramenta, cujo ponto focal inclui todos os dados necessários, seus proprietários e seus endereços de e-mail.

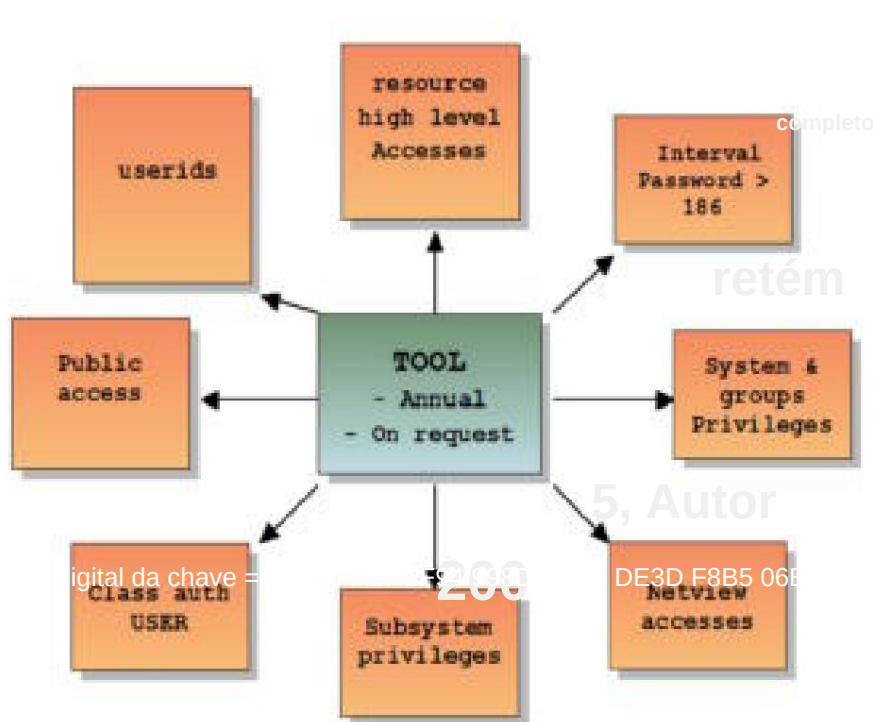


Figura 10: CBN (Validação Contínua da Necessidade de Negócio)

O CBN pode ser ativado sob demanda, selecionando um período específico ou um grupo de sistemas ou um sistema único, bem como 2 tipos de formato.

Um relatório individual para cada colaborador enviado ao seu gerente, ou um relatório departamental enviado ao gerente de serviço (os relatórios podem estar em formato de texto ou HTML).

Para facilitar a compreensão e a administração do sistema, é necessário implementar uma estrutura de tarefas (consulte os pré-requisitos do capítulo). As tarefas serão definidas com uma nomenclatura e uma referência de acesso aos objetos do sistema computacional.

Por exemplo, um grupo chamado « SUPTECH » terá a etiqueta 'Suporte Técnico'.

O nome de usuário associado a este grupo terá uma referência única, indicando que essa pessoa ocupa um cargo de "Suporte Técnico". Além disso, essa arquitetura já está parcialmente implementada, pois a administração é muito mais fácil, bastando atribuir um rótulo ao nome do grupo já criado no software de segurança.

Lista de objetos computacionais incluídos no inventário:

- ID DO USUÁRIO¹

Lista de chaves de acesso aos sistemas.

- Acesso ao nível de recurso

Lista de conexões com um grupo de trabalho ou lista de recursos sensíveis do sistema fora do grupo de trabalho.

- Senha de intervalo

A senha de intervalo é um privilégio porque não é intervalar ou porque o limite do intervalo é superior a um limite referenciado em uma tabela de regras na ferramenta (neste caso, o máximo é de 186 dias).

- Privilégios de sistema e de grupo

Privilégios do sistema para o usuário ou pelo caminho de um grupo, bem como os privilégios do grupo de usuários.

- Acesso

Netview²

Possuir uma chave de acesso ao Netview é um

privilégio. • Privilégios de subsistema.

Lista de privilégios de subsistemas (ex: DB2³ , CICS⁴ ,)

- Usuário com autoridade de classe

Lista de autoridades de classe associadas aos IDs de usuário.

- Lista de recursos de

acesso público.

¹ USERID O termo «ID de usuário» é um termo geral para indicar o usuário, o grupo, o grupo de ID de acesso ou o ID de login.

² Ferramenta de observação de rede Netview (produto de programa da IBM, nota)

³ DB2 DATABASE 2 (um sistema de gerenciamento de banco de dados relacional da IBM)

⁴ CICS Customer Information Control System (IBM)

FLUXO DE DADOS

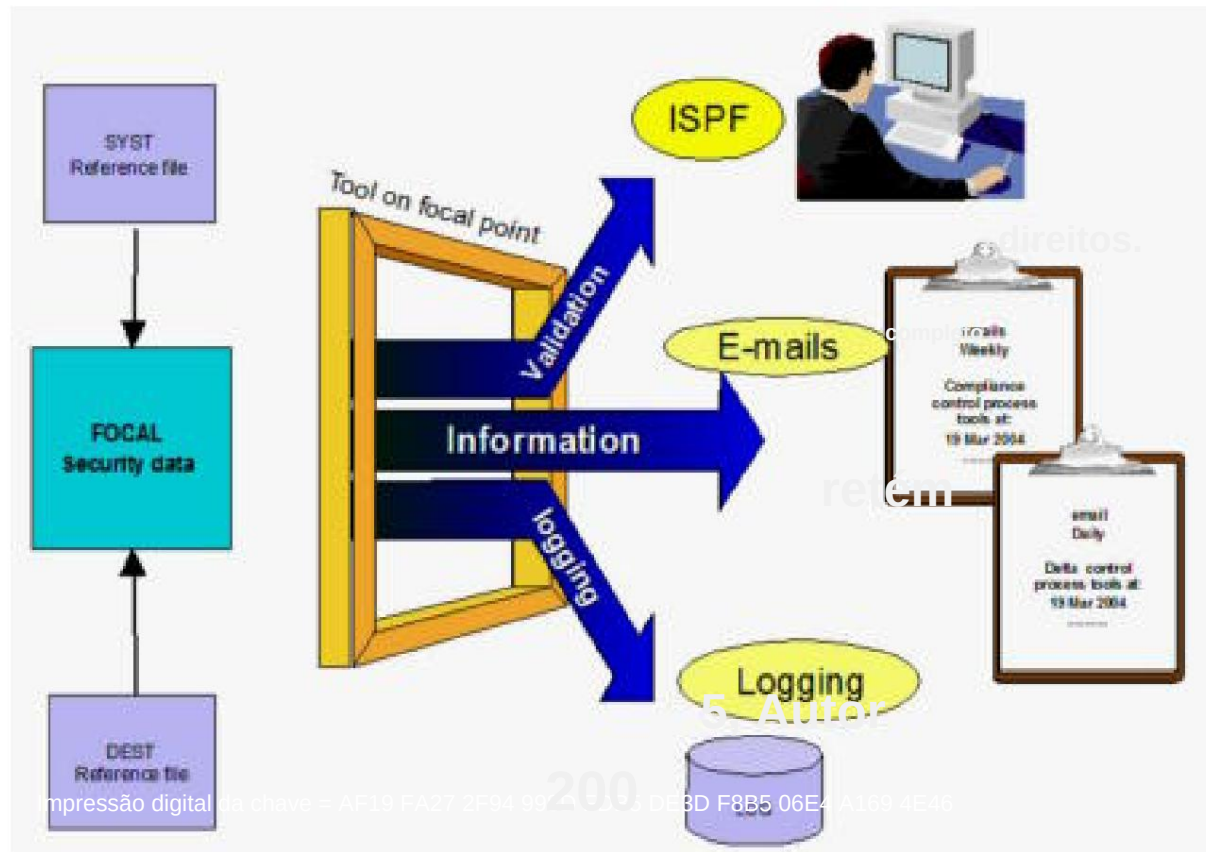


Figura 11: fluxo de dados

Todos os dados de segurança são modelados e, graças às informações em uma tabela de controle, os controles e as variações seguem caminhos diferentes.

- Para ser validado na ferramenta pela interface ISPF
- Informações em um relatório por e-mail
- Evento registrado
- Nenhum controle

Exemplo de fluxo de dados

No gráfico abaixo, que contém os valores por plataforma, está indicado o fluxo de dados em desvio enviado por e-mail para um total de sistemas representando apenas a informação.

Plataforma	Sistemas NB	Usuários NB	Registros NB executam	NB de destinatários de relatórios ¹
ACF2		1 201	3 667	1
OS400	1	130 989	931 973 4	25
RACF	261	499 597	187 853 118	78
TSS		53 003	931 5 242	6
TOTAL	198 11	471 684 800	424	110

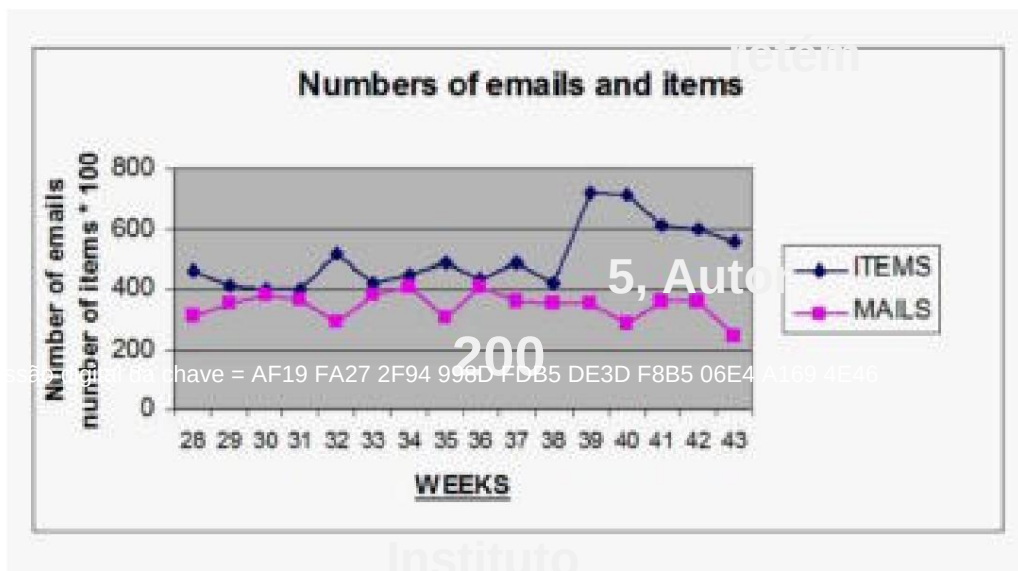


Figura 12: Exemplo de fluxo de dados

O aumento do tráfego está relacionado às integrações de sistemas, que são realmente úteis para os administradores na implementação de regras de segurança.

¹ Destinatário do relatório: pessoa responsável pelo software

Qualidades da FERRAMENTA

Adaptabilidade: O

conceito da ferramenta permite controlar todos os elementos em um curto período de tempo.

Entre duas execuções, o administrador precisa validar ou corrigir a política. O administrador adapta regras específicas às solicitações do cliente, conforme estipulado em contrato.

- Capacidade de gerenciar diferentes níveis de segurança exigidos por nossos clientes
- Capacidade de gerenciar a segurança de acordo com o risco real
- Capacidade de criar relatórios específicos para o gerente ou cliente.

Nível de segurança:

A ferramenta propõe que executemos a aplicação em diferentes períodos de tempo. A obtenção da máxima segurança consiste em poder executar a aplicação com a maior frequência possível.

Quanto mais curto for o período, mais fácil será atingir rapidamente um alto nível de segurança.

Quanto mais importante for o período, mais trabalho teremos para atingir um alto nível de segurança, visto que, durante o longo período intermediário, o nível se deteriorou.

O longo intervalo de tempo entre duas execuções aumenta a vulnerabilidade e não estamos em conformidade com a alta taxa de conformidade. Por exemplo, se a execução for anual, a conformidade se limita a seis meses. Ao decidir realizar outra execução, você terá muitas discrepâncias no seu sistema e muito trabalho para obter uma boa conformidade. Se você deseja um alto nível de segurança, a ferramenta executa um processo delta diariamente e

processo de conformidade semanal. O administrador receberá um breve relatório a cada semana.



Figura 13: Nível do período de segurança

Eficiência

Após a instalação da nova regra, o administrador pode criar uma solicitação no ambiente DB2/QMF para verificar o impacto das novas regras em todos os sistemas gerenciados pela ferramenta e, com outra solicitação, criar um comando específico para diferentes softwares de segurança e executá-lo no sistema de destino.

- Controla regularmente todos os itens de segurança
- Envolve todos os intervenientes para serem mais proativos
- O curso e a documentação estão disponíveis

Transparência

A ferramenta reporta os indicadores estatísticos à gestão.

- Fornecer relatórios precisos e exatos que reflitam a situação real.
- Transmita uma mensagem clara quando nos dirigirmos a outras organizações ou a cliente.

Para ilustrar a transparência com as estatísticas sobre os sistemas OS400 (ver figura: 14).

O primeiro método leva em consideração as regras de segurança internas da empresa, enquanto o segundo método considera as regras de segurança do cliente. No gráfico, podemos observar os diferentes níveis de segurança e cada domínio para dois grupos distintos de regras de segurança (regras internas e regras padrão).

Cálculo da taxa de conformidade

Todas as referências neste gráfico são calculadas com base nas atividades da ferramenta e, para todos os valores, é aplicado um coeficiente de importância.

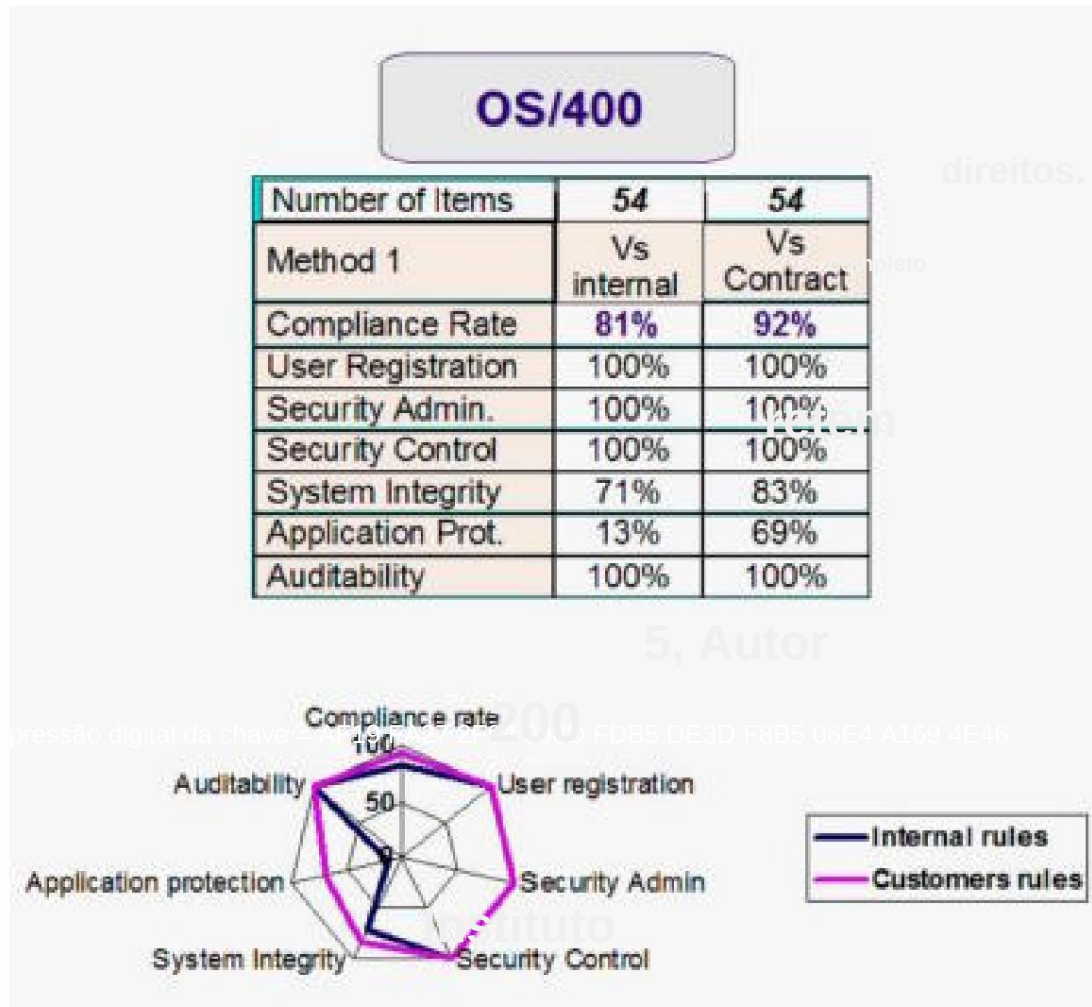


Figura 14: Exemplo de estatísticas de sistemas OS400

Produtividade

- A automatização das operações permite que o administrador trabalhe em eventos que exigem análise, tomada de decisão e inteligência.

Auditabilidade

A atividade da ferramenta deve ser auditável:

Os arquivos de ferramentas são gerenciados como OSR/E.

Todas as ações realizadas através do ISPF são registradas.

Os programas registram o RASTREAMENTO DE AUDITORIA

Os registros e trilhas de auditoria são mantidos por 6 meses.

Custo

Por exemplo, no meu ambiente, a ferramenta está instalada para gerenciar 198 sistemas MVS VM/RACF e 261 sistemas OS400.

Administração da ferramenta.

Sistema alvo: 0,5 dia/sistema/ano [Gerenciamento do extrator](#)

Ponto focal: 20 dias/ano

[Arquivo de destino](#)

[Arquivo RULES](#)

[Arquivo do sistema](#)

Economizando

A economia de tempo está principalmente ligada ao tempo de reação durante um evento. A análise é crucial para a resolução posterior do problema. É preciso entender por que o evento ocorreu e quem o originou. A correção torna-se difícil com o passar do tempo.

Por exemplo:

durante a instalação de um subsistema para dar suporte a um novo aplicativo, se uma regra de segurança não for aplicada, a correção será feita imediatamente caso tenhamos informados. Porém, seis meses depois, com o aplicativo instalado e operacional para muitos usuários, a aplicação da regra de segurança em desacordo exigirá um estudo e uma análise do impacto para os usuários. Nesse caso, o nível de segurança seria classificado como médio.

Em um ambiente idêntico ao descrito no capítulo anterior, estima-se uma economia de 108 pessoas, incluindo todos os administradores (administradores, suporte técnico, etc.) para um alto nível de segurança.

Referências

GIAC. Certificação Global de Segurança da Informação

(O padrão da indústria para conhecimento em segurança)

http://www.giac.org/admin_22.php

Instituto SANS, Políticas do Projeto de Segurança SANS

<http://www.sans.org/resources/policies>

Yves Depoorter, Tarefa Prática GSEC: Aprimorar a segurança do sistema mainframe, padronizando-o.

http://www.giac.org/practical/GSEC/Yves_Depoorter_GSEC.pdf

ISO 9000: Normas ISO que identificam os requisitos para um sistema de gestão da qualidade eficaz. <http://www.iso.org/iso/en/ISOOnline.openpage>

ISO 17790:

<http://www.iso-17799.com/>

SAS 70: (sobre o SAS 70)

<http://www.sas70.com/about.htm>

Sarhanes-Oxley:

<http://www.pwcglobal.com/Extweb/NewCoAtWork.nsf/docid/D0D7F79003C6D64485256CF30074D66C>

Terceirização:

<http://www.cio.com/research/outsourcing/>

http://www.outsourcing-law.com/what_is_outsourcing.htm

IBM Corporation, OS/390: Macros e interfaces RACF,

Número do documento: SA22 7682-05

Resumo: Neste

documento, apresento uma ferramenta dedicada à declaração e ao controle da conformidade com as regras de segurança em sistemas mainframe e midrange. Esta ferramenta controla as configurações de segurança com base em regras que podem variar de um sistema para outro. Relatórios auditáveis são enviados para endereços de e-mail com uma tabela de destinatários. Isso permite responder a auditorias de segurança. A ferramenta oferece a possibilidade de alcançar um alto nível de segurança em um importante conjunto de sistemas.

O processo automatizado gera economia. Com o mesmo número de pessoas, permite gerenciar mais sistemas com maior capacidade de resposta, responsabilidade, nível de segurança e um sistema de arquivamento que nos ajuda a atender às solicitações de controle organizacional em diversas plataformas.

completo

retém

5, Autor

200

Instituto

© SANS

Anexo 1: Extrator de dados

Os dados são coletados de: •

Descarregamento do servidor de segurança (utilitário padrão) • Listas SETROPTS, RVARY, TSS e ACF2 • Saída do monitor de conjunto de dados MVS/VM • Lista de comandos de exibição MVS/JES • Listas de interface SDSF • Varredura da biblioteca de procedimentos JES • IEHLIST (APF/LNK) • Saída do SVCHECK • Listas de subsistemas (DB2, IMS, CICS, NETVIEW, VMBARS...) • Lista de máquinas virtuais (SETEVENT, DIRECTORY,...) • JOBSEC do OS/400 (Perfil do usuário, lista de autorização, lista de grupos, diretórios, acesso público, atributos de rede, descrição do trabalho, valores do sistema, senha padrão, lista de objetos,...)

Anexo 2: Modelagem

Encontre a fonte principal de DOMÍNIO, CATEGORIA e TIPO.

DOMÍNIO	TIPO DE CATEGORIA	
OS400	OSR	BÁSICO
OS400	OSR	PÚBLICO
OS400	JOB	BÁSICO
FERRAMENTA	DESTINO DE CONTROLE	
DFSMS	DFSMS	AUT.
DFSMS	DFSMS	CONTEXTO
OS400	GRUPO	ACESSO
OS400	GRUPO	SYS_AUTH
MVS	MVS	PPT
MVS	MVS	SVC
MVS	REGISTRO RETIDO	
MVS	STC	CONTEXTO
MVS	STC	USUÁRIO
MVS	TSO	CONTEXTO
MVS	UADS	USUÁRIO
NFTP	NFTP	CONTROLAR
NFTP	NFTP	CONTEXTO
NFTP	NFTP	USUÁRIO
NVAS	NVAS	USUÁRIO
OS400	OBJETO	LIB
OMVS	OMVS	PÚBLICO
OMVS	OMVS	CONTEXTO
OS400	OBJETOS CMD	
OS400	OBJETOS NETATTR	
OS400	OBJETOS SYSVAL	
RACF	AULA	AUT.
RACF	ACESSO AO CONJUNTO DE DADOS	
RACF	CONJUNTO DE DADOS BÁSICO	
RACF	CATEGORIA DO CONJUNTO DE DADOS	
RACF	CONJUNTO DE DADOS PÚBLICO	
RACF	GRUPO	ACESSO
RACF	GRUPO	AUT.
RACF	OMVS	AUT.
RACF	RACF	CDT
RACF	RACF	SAÍDA
RACF	RACF	CONTEXTO
RACF	ACESSO A RECURSOS	
RACF	APLICAÇÃO DE RECURSOS	
RACF	RECURSO BÁSICO	
RACF	CATEGORIA DE RECURSOS	
RACF	RECURSO GLOBAL	
RACF	RECURSO OSR_CTL	
RACF	PROGRAMA DE RECURSOS	
RACF	RECURSO PÚBLICO	
RACF	RECURSO VMXEVENT	
RACF	ID DO USUÁRIO	ACESSO
RACF	ID DO USUÁRIO	AUT.
RACF	ID DO USUÁRIO	CONTEXTO
TCP/IP	TCP/IP	CONTEXTO
TSS	ADMIN	AUT.
TSS	IGNORAR	AUT.
TSS	RECURSO BÁSICO	
TSS	TSS	ÁCIDO
TSS	TSS	AUDITORIA
TSS	TSS	PÚBLICO
TSS	TSS	CONTEXTO
OS400	ID DO USUÁRIO	BÁSICO
OS400	ID DO USUÁRIO	NOINTER
OS400	ID DO USUÁRIO	OBJETO
OS400	ID DO USUÁRIO	PSWD
OS400	ID DO USUÁRIO	SYS_AUTH
OS400	ID DO USUÁRIO	USAUDIT
VM	CONFIGURAÇÃO AUTHDASD	
VM	AUTORIZAÇÃO DO USUÁRIO	
VM	AUTORIZAÇÃO DE MANUTENÇÃO DIRETA	
VM	CONFIGURAÇÃO DIRETA	

VM USUÁRIO DE MANUTENÇÃO DIRETA

Anexo 3: Exemplo de modelagem de dados de segurança

TIPO DE CATEGORIA DE DOMÍNIO		SEGURANÇA DE DADOS	VALOR	DATA DE EXECUÇÃO	
RACF	RACF	CONFIGURANDO SETROPTS	ADDCREATOR	ATIVO	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	APLAUDIR	INATIVO	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	CONJUNTO DE DADOS AUTOMÁTICO PRO INATIVO		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	CONJUNTOS DE DADOS CATALOGADOS INATIVOS		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	CMDVIOL	ATIVO	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	MODO DE COMPATIBILIDADE	INATIVO 4	22/10/2004 22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	FRACASSO CONSECUTIVO		
RACF	RACF	CONFIGURANDO SETROPTS	MODELAGEM DE CONJUNTOS DE DADOS	SER FEITO PARA	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	REGISTRO EIM	NENHUM	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	NAMI GÊNÉRICO APRIMORADO INATIVO		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	APAGAR AO RISCAR	ATIVO	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	APAGAR AO RISCAR POR S INATIVO		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	SOMENTE PARA PROPRIETÁRIOS GÊNERICOS	ATIVO	22/10/2004 22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	MODELO DE CONJUNTO DE DADOS DE GRUPO ATIVO		
RACF	RACF	CONFIGURANDO SETROPTS	IDs de usuário inativos automáticos	186	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	INICIALIZAR ESTATÍSTICAS	ATIVO	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	SENHA DE INSTALAÇÃO INATIVA		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	JES-BATCHALLRACF OPTI ACTIVE		22/10/2004 22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	JES-EARLYVERIFY OPTI ACTIVE		
RACF	RACF	CONFIGURANDO SETROPTS	OPÇÃO JES-XBMLLRACF ATIVA		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	KERBLVL	0	22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	LISTA DE GRUPOS COM ACESSO ATIVO		22/10/2004
RACF	RACF	CONFIGURANDO SETROPTS	ATIVO DE VÁRIOS NÍVEIS	INATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO SETROPTS AMAJOPTS CLASSE		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO SETROPTS AMAJOPTS COMANDO GÊNÉRICO		ATIVO	22/10/2004 22/10/2004
RACF	RACF	CONFIGURAÇÃO DE PERFIL GÊNÉRICO SETROPTS AMAJOPTS		ATIVO	
RACF	RACF	CONFIGURAÇÃO SETROPTS AMAJOPTS LOGOPTIONS		SEMPRE	22/10/2004
RACF	RACF	CONFIGURAÇÃO SETROPTS AMAJOPTS RACLISTA		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE PERFIL GÊNÉRICO DO APLICATIVO SETROPTS		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE OPÇÕES DE APLICATIVO SETROPTS LOGOPTIONS		PADRÃO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE AUDITORIA DE APLICATIVOS SETROPTS		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO SETROPTS APPCPORT CLASSE		ATIVO	22/10/2004 22/10/2004
RACF	RACF	CONFIGURAÇÃO DE COMANDO GÊNÉRICO SETROPTS APPCPORT		ATIVO	
RACF	RACF	CONFIGURAÇÃO DO PERFIL GÊNÉRICO DO APPCPORT SETROPTS		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO SETROPTS APPCPORT LOGOPTIONS		PADRÃO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE AUDITORIA DO APPCSERV (SETROPTS)		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE OPÇÕES DE LOGIN DO APPCSERV		PADRÃO	22/10/2004 22/10/2004
RACF	RACF	CONFIGURAÇÃO DE AUDITORIA DE APLICATIVOS SETROPTS		ATIVO	
RACF	RACF	CONFIGURAÇÃO SETROPTS APPCSI CLASSE		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DE COMANDO GÊNÉRICO SETROPTS APPCSI		ATIVO	22/10/2004
RACF	RACF	CONFIGURAÇÃO DO PERFIL GÊNÉRICO DO APPCSI SETROPTS		ATIVO	